

Capítulo 7

Inteligencia de Amenazas y el Framework MITRE ATT&CK: de la seguridad reactiva a la anticipación táctica del adversario

Resumen

Este capítulo desarrolla la transición conceptual y operativa desde la seguridad reactiva tradicional hacia la inteligencia de amenazas (Cyber Threat Intelligence, CTI) como disciplina proactiva. Se examinan la jerarquía dato–información–inteligencia, el ciclo de inteligencia en sus seis etapas, los tres niveles de consumo (estratégico, operacional y táctico) y la Pirámide del Dolor de Bianco como criterio de priorización defensiva. A continuación se introduce el framework MITRE ATT&CK como lenguaje común de la ciberdefensa moderna y se aplica al mapeo de una intrusión de ransomware. El capítulo cierra con la operacionalización de la inteligencia mediante IoC, STIX/TAXII, MISP y el protocolo TLP, el panorama del cibercrimen 2026, el proceso DFIR y el marco legal peruano de delitos informáticos, articulando una hoja de ruta de madurez CTI para organizaciones con recursos limitados.

Palabras clave

Inteligencia de amenazas · Cyber Threat Intelligence · MITRE ATT&CK · Pirámide del Dolor · Ciclo de inteligencia · Indicadores de compromiso · STIX/TAXII · MISP · DFIR · Ley N.º 30096

7.1. De la reacción a la anticipación

Los capítulos precedentes construyeron el andamiaje de la seguridad de la información: los marcos de gobierno (ISO/IEC 27001:2022 e ISO 31000:2018), las herramientas de evaluación cualitativa y cuantitativa del riesgo, los indicadores de monitoreo continuo y la arquitectura del centro de operaciones de seguridad. Todos esos elementos comparten, sin embargo, una limitación estructural: operan principalmente sobre lo que ya ocurrió. El presente capítulo introduce el cambio de paradigma más disruptivo del curso, el que distingue a un equipo de seguridad maduro de uno que se limita a responder alertas: aprender a pensar como el adversario.

La inteligencia de amenazas —Cyber Threat Intelligence o CTI— no es una herramienta ni un producto de software. Es una disciplina de conocimiento estructurado sobre quién ataca a una organización, por qué, cómo, cuándo y con qué medios. El término «adversario» no designa un código malicioso anónimo, sino grupos humanos organizados —criminales, hacktivistas o actores patrocinados por Estados— con objetivos estratégicos, recursos, herramientas y metodologías propias. Esta disciplina no es ajena al cuerpo normativo ya estudiado: el control A.5.7 (Threat

intelligence) de la norma ISO/IEC 27001:2022 exige a las organizaciones certificadas implementar un proceso estructurado de inteligencia de amenazas (International Organization for Standardization, 2022). El presente capítulo desarrolla operativamente qué significa ese control.

7.1.1. El modelo reactivo y sus tres limitaciones estructurales

La seguridad tradicional opera en tiempo pasado y se caracteriza por tres rasgos que, en el panorama de amenazas contemporáneo, se han vuelto deficitarios. El primero es que espera la materialización del ataque para responder: el evento ocurre, se detecta —con frecuencia con horas o días de retraso—, se responde y, en el mejor de los casos, se documenta. La compresión del tiempo de ataque hace que este modelo sea estructuralmente insuficiente, pues cuando el equipo reactivo detecta y responde, los datos ya han sido exfiltrados o el ransomware ya se ha desplegado.

El segundo rasgo es la centralidad exclusiva del perímetro. La seguridad perimetral concibe la organización como un castillo defendido por muros (firewalls), fosos (zonas desmilitarizadas) y guardias (sistemas de prevención de intrusiones). El problema es que los atacantes modernos no atraviesan el muro: ingresan por el correo electrónico de un empleado, por la credencial robada de un contratista o por la vulnerabilidad en el software de un proveedor. El perímetro como única línea de defensa colapsó cuando el trabajo remoto, la computación en la nube y los dispositivos móviles disolvieron las fronteras físicas de la red corporativa. El tercer rasgo es que el modelo reactivo mide exclusivamente incidentes pasados: número de incidentes cerrados, tiempo de respuesta promedio, porcentaje de alertas procesadas. Son indicadores retrospectivos, sin componente predictivo alguno.

7.1.2. El modelo proactivo: anticipar, comprender y predecir

La CTI, en contraste, opera en tiempo futuro. Su producto es conocimiento sobre lo que podría ocurrir, fundamentado en lo que grupos adversariales específicos han hecho históricamente, hacen en el presente y tienen la capacidad de hacer en el corto plazo. Este conocimiento permite desplegar contramedidas antes de la ejecución del ataque: bloquear una dirección IP asociada a una campaña activa, eliminar un correo de phishing que está siendo distribuido en ese momento o parchar una vulnerabilidad que un grupo conocido explota activamente. La CTI estudia al adversario y no solo a sus artefactos técnicos, distinción que constituye el núcleo de la Pirámide del Dolor que se examina más adelante. Finalmente, la CTI madura aplica metodologías de análisis estructurado

para producir predicciones probabilísticas; no se trata de clarividencia, sino de la misma metodología que emplean los servicios de inteligencia nacionales, adaptada al dominio digital.

Cuadro 7.1. Seguridad reactiva frente a inteligencia de amenazas proactiva

Dimensión	Seguridad reactiva	Cyber Threat Intelligence
Pregunta clave	¿Qué pasó?	¿Quién nos ataca, cómo y cuándo?
Orientación temporal	Pasado: evento ya consumado	Futuro: señales previas al evento
Foco	Perímetro y sistemas	Comportamiento humano y técnico del atacante
Producto	Registros, informes de incidente	Inteligencia accionable, alertas tempranas
Posición del defensor	Siempre llega tarde	Actúa antes de la ejecución
Efecto sobre el riesgo	No modifica la exposición futura	Reduce la superficie de ataque de forma anticipada

Nota. Definición de CTI de Gartner.

La objeción del presupuesto limitado

Una afirmación frecuente en entidades públicas con presupuesto de TI restringido sostiene: «No podemos pagar un servicio de CTI comercial, así que no podemos ser proactivos». La afirmación es incorrecta. Existe inteligencia de amenazas gratuita y accesible —feeds OSINT como Abuse.ch, AlienVault OTX, el catálogo CISA KEV y las comunidades abiertas de MISP. La barrera no es económica sino metodológica: requiere proceso, no presupuesto.

7.2. La jerarquía del conocimiento: dato, información e inteligencia

La inteligencia no es un insumo crudo sino el resultado final de un proceso de refinamiento. La consultora Gartner ofrece la definición canónica de CTI como «conocimiento basado en evidencia —incluyendo contexto, mecanismos e indicadores— sobre una amenaza, que permite tomar decisiones informadas y accionables». Tres términos de esta definición merecen atención. El conocimiento es «basado en evidencia», es decir, proviene de la observación, el análisis y la validación, no de la especulación. Incorpora «contexto, mecanismos e indicadores», porque no basta con saber que un evento ocurrió: hay que comprender el contexto organizacional y geopolítico, el mecanismo técnico del ataque y los indicadores que permiten detectarlo. Y es «accionable», criterio de calidad definitivo: si un producto no habilita una acción defensiva concreta, no es inteligencia, sino apenas información o dato.

La distinción entre estos tres niveles de madurez del conocimiento puede ilustrarse con un ejemplo progresivo. Una dirección IP aislada —el dato— es un hecho sin contexto, no accionable por sí solo. Cuando se le añade que esa IP envió cuatrocientos correos maliciosos a la institución, se obtiene información: se sabe qué pasó, pero no qué hacer. Solo cuando se establece que se trata de la infraestructura de un grupo adversarial conocido por atacar al sector educativo, y que requiere bloqueo inmediato y alerta al centro de operaciones, el conocimiento se convierte en inteligencia plena: contexto, atribución y recomendación accionable.

Cuadro 7.2. El mismo evento de seguridad en los tres niveles de la jerarquía

Nivel	Enunciado	Utilidad defensiva
Dato	SHA-256: a1b2c3d4e5...	Ninguna aislada; cualquier variante cambia el hash.
Información	El archivo es un loader de LockBit 3.0 observado en el sector financiero peruano en mayo de 2026.	Permite bloquear ese archivo específico.
Inteligencia	LockBit opera mediante intermediarios de acceso inicial que venden accesos RDP expuestos; el loader es el primer paso (T1078) antes del cifrado. Se requiere revisión urgente de accesos RDP, MFA forzado y caza de movimiento lateral en 72 horas.	Permite contener la campaña completa, no solo un archivo.

Nota. La sigla RDP designa el Protocolo de Escritorio Remoto; MFA, la autenticación multifactor.

El valor operativo de esta jerarquía radica en que invierte la lógica del centro de operaciones puramente reactivo, que procesa miles de datos diarios pero produce escasa inteligencia y, en consecuencia, padece el fenómeno de la «fatiga de alertas»: el volumen es tan elevado que los analistas dejan de investigar cada evento. La CTI parte de la pregunta inversa —qué se quiere saber— y solo entonces recolecta los datos relevantes. La pregunta del analista no es «¿qué datos tengo?», sino «¿qué pregunta estratégica debo responder y qué datos me ayudan a hacerlo?».

7.3. El ciclo de inteligencia

La producción de inteligencia sigue un proceso estructurado de seis etapas que opera de manera circular y permanente, no lineal ni episódica. Una organización que ejecuta el ciclo una sola vez y lo abandona no posee un programa CTI, sino un proyecto puntual. La primera etapa, Dirección, es fundacional: consiste en definir los Requisitos de Inteligencia, traduciendo los objetivos estratégicos de la organización en preguntas específicas y priorizadas. Sin requisitos bien definidos, el programa produce contenido genérico que nadie consume. La segunda etapa,

Recolección, obtiene sistemáticamente los datos crudos que responden a esos requisitos, a partir de fuentes abiertas (OSINT), humanas (HUMINT), técnicas propias (TECHINT), comerciales y de compartición sectorial oficial.

La tercera etapa, Procesamiento, transforma los datos crudos en insumos utilizables mediante normalización de formatos, descifrado, deduplicación y enriquecimiento inicial; es una fase intensiva en automatización, ejecutada por plataformas como MISP, OpenCTI o Cortex. La cuarta etapa, Análisis, constituye el corazón intelectual del ciclo: mediante técnicas estructuradas —el Análisis de Hipótesis en Competencia (ACH), el Diamond Model, el análisis sobre la cadena de ataque y el mapeo en MITRE ATT&CK— el analista convierte los datos procesados en conocimiento accionable, declarando explícitamente el nivel de confianza de sus conclusiones. La quinta etapa, Difusión, entrega el conocimiento al consumidor correcto, en el formato adecuado y a tiempo, pues la inteligencia tiene una vida útil determinada: un informe sobre una campaña activa que llega tres semanas tarde ya no es accionable.

La etapa crítica: Retroalimentación

La sexta etapa —Retroalimentación— es la que cierra el ciclo y lo hace sostenible, y es también la más frecuentemente omitida. Su función es evaluar la utilidad de la inteligencia producida y refinar los Requisitos de Inteligencia originales. Sin ella, el programa CTI produce contenido desconectado de las necesidades reales: el analista trabaja en el vacío y el consumidor recibe algo que no le sirve. Los consumidores deben responder si la inteligencia fue relevante para sus decisiones, si llegó a tiempo, si tenía el nivel de detalle apropiado y qué preguntas quedaron sin respuesta. Estas respuestas refinan los requisitos y arrancan un nuevo ciclo, más focalizado. El error más común es tratar el ciclo como una línea recta que termina en la difusión; el ciclo es permanente.

7.4. Los tres consumidores de la inteligencia

Un error estructural frecuente en los programas CTI incipientes consiste en producir un único tipo de informe y distribuirlo a toda la organización. El resultado es doble: los directivos se ahogan en detalles técnicos que no comprenden, mientras que los analistas reciben informes tan abstractos que no logran traducirlos en acciones. La segmentación de la inteligencia en tres niveles no es administrativa, sino que refleja diferencias reales de audiencia, horizonte temporal, tipo de decisión y formato de consumo.

La inteligencia estratégica se dirige a la alta gerencia, el directorio y, en el contexto universitario, el rectorado. Se enfoca en tendencias globales del cibercrimen, riesgos geopolíticos

con impacto digital y priorización de inversiones, con un horizonte de meses a años y un formato de resúmenes ejecutivos. La afirmación de que el sector educativo es un blanco prioritario de ransomware permite a un rectorado decidir el aumento del presupuesto de seguridad sin necesidad de conocer la técnica específica empleada. La inteligencia operacional se dirige a los jefes de seguridad y defensores de red; se centra en campañas activas, infraestructura de ataque y perfiles de actores con sus tácticas, técnicas y procedimientos, con un horizonte de semanas a meses. La inteligencia táctica, finalmente, se dirige a los analistas del centro de operaciones e ingenieros de seguridad, y consiste en indicadores de compromiso y reglas de detección listas para integrarse en las herramientas, con un horizonte inmediato de horas a días.

Cuadro 7.3. Las tres dimensiones de la inteligencia comparadas

Dimensión	Estratégica	Operacional	Táctica
Audiencia	Alta dirección / directorio	CISO / jefes de seguridad	Analistas SOC / ingenieros
Horizonte	Meses a años	Semanas a meses	Horas a días
Pregunta clave	¿En qué invertir?	¿Qué actores nos acechan?	¿Qué bloquear o detectar ahora?
Formato	Resumen ejecutivo, infografía	Informe de actor o campaña	Feed de IoC, regla Sigma/YARA
Vida útil	Meses	Semanas	Horas a días

Nota. CISO designa al director de seguridad de la información; SOC, al centro de operaciones de seguridad.

7.5. La Pirámide del Dolor

Introducida por David Bianco en 2013, la Pirámide del Dolor se convirtió en uno de los modelos conceptuales más influyentes de la ciberdefensa moderna (Bianco, 2013). Su premisa es deceptivamente simple: distintos tipos de indicadores de compromiso imponen distintos niveles de «dolor» al adversario cuando son bloqueados por el defensor. La elección de qué tipo de indicador defender determina si se resuelve el problema o si solo se aplica un parche temporal.

En la base de la pirámide se ubican los valores hash (MD5, SHA-1, SHA-256), cuyo bloqueo es trivial de evadir: basta con modificar un bit del archivo para generar un hash completamente distinto, y los grupos sofisticados producen cientos de variantes en minutos. Por encima se sitúan las direcciones IP, evasibles en horas mediante rotación de infraestructura, y los nombres de dominio, ligeramente más persistentes pero igualmente sustituibles por adversarios que registran dominios por adelantado. El cuarto nivel, los artefactos de red y host —patrones de beacon, claves

de registro, rutas del sistema de archivos—, ya resulta molesto de cambiar porque exige modificar el código del malware. El quinto nivel, las herramientas, es desafiante: bloquear los frameworks de post-explotación del adversario lo obliga a desarrollar o adaptar significativamente su instrumental, con alto costo y tiempo.

La cúspide: las tácticas, técnicas y procedimientos (TTP)

El vértice de la pirámide —el nivel de máximo dolor— lo ocupan las tácticas, técnicas y procedimientos: el comportamiento fundamental del adversario, es decir, cómo piensa, planifica y ejecuta. A diferencia de los hashes (que cambian en minutos) o las IP (que rotan en horas), las TTP son extraordinariamente estables, porque reflejan el conocimiento acumulado del grupo y sus procesos operativos entrenados. Como sintetiza el modelo: bloquear indicadores técnicos básicos es un parche temporal; desactivar una TTP neutraliza la campaña entera. Bloquear el hash de un loader dura quince minutos —el tiempo que el atacante tarda en recompilar—; implementar una mitigación de la técnica de volcado de credenciales perdura indefinidamente contra esa técnica.

La implicación práctica para la priorización defensiva es directa. Los indicadores de los niveles inferiores deben procesarse automáticamente —son útiles para cobertura masiva pero no requieren inversión analítica humana significativa—, mientras que el esfuerzo analítico de los profesionales debe concentrarse en identificar las TTP del adversario relevante y diseñar mitigaciones persistentes. La madurez CTI de una organización puede medirse precisamente por el nivel de la pirámide en el que es capaz de operar: si solo bloquea hashes, opera en el nivel uno; si detecta TTP y las mapea en ATT&CK, opera en el nivel superior.

7.6. El framework MITRE ATT&CK

MITRE ATT&CK (Adversarial Tactics, Techniques, and Common Knowledge) nació en 2013 como un proyecto interno de MITRE Corporation para documentar el comportamiento de los adversarios observado en entornos reales (Strom et al., 2018). Desde entonces ha evolucionado hasta convertirse en el estándar de facto de la ciberseguridad global, empleado por agencias como CISA, la NSA y la ENISA, así como por la práctica totalidad de las organizaciones de ciberseguridad relevantes. Su carácter público y gratuito lo hace accesible a cualquier equipo con independencia de su presupuesto, atributo decisivo para entidades con recursos limitados.

El framework se organiza en dos dimensiones complementarias. Las tácticas representan el «por qué» del ataque, esto es, el objetivo que el adversario persigue en un momento dado; no son acciones técnicas, sino intenciones. La versión Enterprise vigente cataloga catorce tácticas que conforman la secuencia lógica de una intrusión, desde el reconocimiento hasta el impacto. Las

técnicas, por su parte, representan el «cómo»: más de doscientas describen el método concreto mediante el cual el adversario alcanza cada objetivo táctico, y muchas se subdividen en sub-técnicas que detallan variantes específicas. Así, la táctica de Acceso Inicial (TA0001) puede realizarse mediante la técnica de Phishing (T1566), que a su vez comprende el adjunto malicioso (T1566.001), el enlace malicioso (T1566.002) y el phishing a través de servicios de terceros (T1566.003).

Cuadro 7.4. Las catorce tácticas de MITRE ATT&CK Enterprise

N.º	Táctica (identificador)	Objetivo del adversario
1	Reconnaissance (TA0043)	Recopilar información sobre el blanco antes del ataque.
2	Resource Development (TA0042)	Preparar infraestructura, cuentas y herramientas.
3	Initial Access (TA0001)	Obtener acceso inicial al entorno de la víctima.
4	Execution (TA0002)	Ejecutar código malicioso en el sistema comprometido.
5	Persistence (TA0003)	Mantener el acceso tras reinicios o cambios de credencial.
6	Privilege Escalation (TA0004)	Obtener permisos de nivel superior.
7	Defense Evasion (TA0005)	Evitar la detección por los controles de seguridad.
8	Credential Access (TA0006)	Robar credenciales de autenticación.
9	Discovery (TA0007)	Mapear el entorno interno: usuarios, sistemas y red.
10	Lateral Movement (TA0008)	Desplazarse por la red hacia sistemas adicionales.
11	Collection (TA0009)	Recopilar datos de interés para la exfiltración.
12	Command and Control (TA0011)	Establecer comunicación con la infraestructura atacante.
13	Exfiltration (TA0010)	Extraer los datos robados fuera de la organización.
14	Impact (TA0040)	Manipular, interrumpir o destruir sistemas y datos.

Nota. Fuente: MITRE ATT&CK Enterprise Matrix (The MITRE Corporation, 2024).

La transformación que ATT&CK introduce en la defensa opera por cuatro vías. En primer lugar, provee un lenguaje común: cuando un informe menciona la técnica T1566.001, cualquier analista del mundo comprende exactamente de qué se habla, lo que facilita el intercambio de

inteligencia y la colaboración sectorial. En segundo lugar, la herramienta ATT&CK Navigator permite evaluar la cobertura defensiva coloreando la matriz completa según las técnicas que el centro de operaciones puede detectar, revelando un «mapa de calor» de los vacíos. En tercer lugar, habilita la caza de amenazas basada en hipótesis, en la que el analista parte de una técnica conocida del adversario y busca su evidencia en los registros. En cuarto lugar, para cada técnica ATT&CK documenta las plataformas afectadas, las fuentes de datos, las técnicas de detección y las mitigaciones, convirtiéndose en una biblioteca de diseño defensivo y no en un mero catálogo de ataques.

7.7. Deconstrucción de una intrusión de ransomware mediante ATT&CK

La aplicación más ilustrativa del framework consiste en mapear una intrusión real sobre sus técnicas y derivar, para cada una, la contramedida correspondiente. Una intrusión típica de ransomware atraviesa cuatro fases. La primera es el acceso inicial mediante phishing (T1566), la técnica más prevalente del panorama actual: según el Informe de Investigaciones de Brechas de Datos de Verizon, el 68 % de las brechas involucra un elemento humano no malicioso —una persona que comete un error o cae en un ataque de ingeniería social— (Verizon, 2024). El actor de ransomware moderno no necesita explotar vulnerabilidades sofisticadas: un empleado que abre un adjunto malicioso entrega el acceso inicial. La contramedida combina filtros de correo impulsados por inteligencia artificial con el entrenamiento del personal en técnicas OSINT, de modo que cada usuario reconozca qué información pública sobre sí mismo podría emplear un atacante para personalizar el engaño.

La segunda fase es el escalamiento de privilegios mediante el volcado de credenciales del sistema operativo (T1003), técnica que extrae credenciales de la memoria —emblemáticamente con la herramienta Mimikatz, que las obtiene del proceso LSASS de Windows—. Esta técnica es la bisagra entre la intrusión limitada y el control total del entorno. La contramedida combina Credential Guard, tecnología basada en virtualización que aísla LSASS impidiendo la extracción, con una arquitectura Zero Trust en la que ningún usuario o dispositivo es confiado por defecto. La tercera fase es el movimiento lateral mediante recursos compartidos SMB (T1021.002): con credenciales válidas, el actor se desplaza hacia los sistemas de mayor valor empleando un tráfico que resulta legítimo y frecuente en entornos Windows, por lo que su detección exige análisis de comportamiento más que de firmas. La contramedida es la microsegmentación de la red, que

impide que el compromiso de un segmento alcance directamente a otro, reforzada por la autenticación multifactor en los accesos internos.

Fase final: el impacto y la última línea de defensa

La cuarta fase es el impacto mediante el cifrado de datos para extorsión (T1486), técnica que convierte el acceso en daño económico tangible: el actor despliega el payload —usualmente desde un controlador de dominio comprometido para alcance máximo—, cifra los archivos y elimina las copias de sombra para dificultar la recuperación. La contramedida decisiva son los respaldos inmutables y fuera de línea bajo la regla 3-2-1-1-0 (tres copias, dos medios distintos, una externa, una inmutable o aislada físicamente, cero errores en la última prueba de restauración), complementados por una respuesta forense proactiva. Un ransomware que no puede cifrar ni alcanzar los respaldos pierde su poder de extorsión.

Cuadro 7.5. Mapeo de fases, técnicas ATT&CK y contramedidas en una intrusión de ransomware

Fase 1 — Acceso inicial · T1566 Phishing → Filtros de correo con IA + entrenamiento OSINT.

Fase 2 — Escalamiento de privilegios · T1003 Volcado de credenciales → Credential Guard + arquitectura Zero Trust.

Fase 3 — Movimiento lateral · T1021.002 SMB/recursos compartidos → Microsegmentación de red + MFA interno.

Fase 4 — Impacto · T1486 Cifrado para impacto → Respaldos inmutables offline (3-2-1-1-0) + DFIR proactivo.

La lección transversal del caso es que ATT&CK no es un catálogo de ataques, sino una guía de diseño de defensa: para cada técnica del adversario existe al menos una mitigación documentada en la propia base de conocimiento de MITRE. El ciclo virtuoso consiste en identificar las TTP del adversario relevante mediante inteligencia operacional, mapearlas en ATT&CK, implementar las mitigaciones documentadas y verificar su eficacia mediante simulación controlada con herramientas como Atomic Red Team.

7.8. Operacionalización de la inteligencia

El conocimiento de inteligencia que no alimenta automáticamente las herramientas de defensa es inteligencia desperdiciada. Un analista que copia y pega indicadores manualmente en una lista negra trabaja a velocidad humana, mientras que la automatización opera a velocidad de máquina. La operacionalización descansa sobre cuatro componentes que deben funcionar de manera articulada para que la inteligencia se ingiera automáticamente en firewalls, sistemas de detección y respuesta de endpoints (EDR) y sistemas de gestión de eventos de seguridad (SIEM).

El primer componente son los indicadores de compromiso (IoC): los artefactos tácticos — hashes, direcciones IP, dominios, user-agents y reglas de detección— listos para el consumo automatizado de las plataformas de seguridad. El segundo son los estándares STIX y TAXII. Antes de su adopción, cada organización compartía inteligencia en formatos propietarios imposibles de procesar automáticamente. STIX (Structured Threat Information eXpression) es un lenguaje de representación de inteligencia en formato estructurado que define objetos estandarizados — indicador, actor de amenaza, malware, campaña— y sus relaciones; TAXII (Trusted Automated eXchange of Indicator Information) es el protocolo de transporte que permite a un cliente suscribirse a un servidor y recibir actualizaciones en tiempo real. Su impacto es la base de la defensa colectiva: la inteligencia publicada en STIX/TAXII puede ser consumida por cualquier sistema compatible, sin intervención humana, en segundos.

El tercer componente es la plataforma MISP (Malware Information Sharing Platform), software de código abierto desarrollado por el centro de respuesta a incidentes de Luxemburgo y empleado por cientos de organizaciones en más de setenta países, incluido el CERT-PE en el Perú. MISP centraliza un repositorio único de indicadores y eventos, correlaciona automáticamente las coincidencias entre organizaciones de una red de confianza, y distribuye la inteligencia en múltiples formatos para su ingesta directa. Para una universidad o entidad pública peruana, constituye el punto de entrada más accesible a la defensa colectiva, por ser gratuito y disponer de comunidades abiertas. El cuarto componente es el protocolo TLP (Traffic Light Protocol), sistema de clasificación de la sensibilidad de la inteligencia adoptado por el FIRST como estándar global, cuya metáfora del semáforo regula con precisión a quién puede comunicarse cada información, desde la máxima restricción (TLP:RED, solo para destinatarios nombrados) hasta la divulgación pública (TLP:CLEAR).

7.9. El panorama del cibercrimen: vectores emergentes de 2026

La inteligencia artificial ha reducido las barreras de entrada para las operaciones ofensivas, configurando un panorama de amenazas en el que tres vectores merecen atención particular. El primero es el AI-phishing: correos hiperpersonalizados generados a escala mediante modelos de lenguaje maliciosos, sin errores gramaticales y contextualizados con información pública de la víctima obtenida por OSINT. La ausencia de los errores ortográficos que históricamente delataban el phishing eleva sustancialmente la tasa de éxito de estos engaños. El segundo vector son los

deepfakes y el vishing ejecutivo: la suplantación de voz e imagen en tiempo real para el fraude del directivo, empleada para autorizar transferencias financieras o extraer credenciales críticas mediante llamadas de soporte falsas. Casos documentados de fraude por suplantación con deepfake han alcanzado pérdidas de decenas de millones de dólares en una sola operación.

El tercer vector es el qrishing evolucionado: ataques físico-digitales que emplean códigos QR fraudulentos en infraestructuras corporativas o eventos para eludir las pasarelas de seguridad perimetral del correo y atacar directamente el dispositivo móvil de la víctima, que suele estar menos protegido que el equipo corporativo. Estos tres vectores comparten una característica: explotan la confianza humana antes que la vulnerabilidad técnica, lo que confirma la centralidad del factor humano en la superficie de ataque contemporánea y la pertinencia de las contramedidas centradas en la concienciación y la verificación.

7.10. Respuesta a incidentes basada en inteligencia (DFIR)

Cuando la prevención falla, la contención estructural de la amenaza se organiza en torno a la disciplina de análisis forense digital y respuesta a incidentes (Digital Forensics and Incident Response, DFIR), que articula cuatro pilares secuenciales. El primer pilar, detectar y verificar, realiza el triaje inicial utilizando los indicadores de CTI, elimina los falsos positivos y confirma la brecha real. El segundo pilar, contener, ejecuta el aislamiento rápido —la cuarentena de red— de los sistemas y endpoints comprometidos para frenar el movimiento lateral del adversario. El tercer pilar, erradicar, procede a la eliminación quirúrgica de la presencia maliciosa, la neutralización de las herramientas del atacante y el cierre de la vulnerabilidad explotada. El cuarto pilar, recuperar, restaura las operaciones desde los respaldos inmutables, intensifica el monitoreo posterior al incidente y fortalece sistémicamente la postura de seguridad.

La inteligencia de amenazas atraviesa los cuatro pilares: orienta la detección al proveer los indicadores de búsqueda, informa la contención al revelar las vías de movimiento lateral del actor, guía la erradicación al documentar las técnicas de persistencia empleadas, y nutre la recuperación al señalar qué controles deben reforzarse. Un equipo de DFIR maduro no improvisa durante la crisis: dispone de procesos, herramientas e inteligencia de contexto listos para activarse en minutos.

7.11. Gobierno y marco legal peruano

La seguridad de la información es, simultáneamente, un imperativo técnico, jurídico y regulatorio, integrado en la tríada de gobierno, riesgo y cumplimiento (GRC). En el ordenamiento peruano, la Ley N.º 30096, Ley de Delitos Informáticos, y su modificatoria, la Ley N.º 30171, tipifican legalmente el acceso ilícito, la interceptación de datos, el fraude informático y la suplantación de identidad, constituyendo la base jurídica para proceder contra el cibercrimen a escala nacional (Congreso de la República del Perú, 2013). En el plano internacional, la adhesión del Perú al Convenio de Budapest sobre la Ciberdelincuencia permite la cooperación policial transfronteriza y la homogeneización penal para delitos que operan sin fronteras geográficas, dimensión indispensable frente a adversarios cuya infraestructura se distribuye entre múltiples jurisdicciones.

El procedimiento de escalamiento y denuncia exige preservar la cadena de custodia de la evidencia forense, requisito sin el cual la prueba digital pierde validez procesal. La denuncia se eleva a la División de Investigación de Delitos de Alta Tecnología de la Policía Nacional del Perú (DIVINDAT-PNP) y, cuando corresponde por afectación de datos personales, a la Autoridad Nacional de Protección de Datos Personales, en concordancia con la Ley N.º 29733, Ley de Protección de Datos Personales. Para una entidad de Ayacucho, conocer esta ruta de escalamiento antes de sufrir un incidente es tan importante como disponer de las contramedidas técnicas, pues la respuesta legal mal ejecutada compromete tanto la persecución del delito como la posición jurídica de la propia organización.

La asimetría del conocimiento

El dominio sobre cómo operan los atacantes otorga un poder técnico considerable. El verdadero diferencial del profesional en ciberseguridad reside en emplear esta inteligencia exclusivamente para garantizar la resiliencia operativa y proteger la continuidad del tejido social y empresarial. El conocimiento de las tácticas adversariales conlleva una responsabilidad ética y legal ineludible: se adquiere para defender, nunca para atacar.

7.12. Construyendo resiliencia organizacional: una hoja de ruta de madurez CTI

La implementación de un programa CTI maduro puede estructurarse en tres fases progresivas, diseñadas para ser viables incluso en organizaciones con recursos limitados. La primera fase, de fundamentos, abarca los primeros tres meses y se apoya en feeds OSINT gratuitos como Abuse.ch, en la construcción de una cultura anti-phishing y en procesos básicos de reporte de incidentes. La

segunda fase, de estructura, se extiende entre los tres y los nueve meses, e incorpora la adopción de MITRE ATT&CK, el despliegue de la plataforma MISP y la realización de simulacros técnicos internos. La tercera fase, de inteligencia proactiva, abarca de los nueve a los dieciocho meses y consolida la caza de amenazas basada en hipótesis, la integración con el centro de operaciones y la elaboración de tableros de control para el directorio.

Cuadro 7.6. Hoja de ruta de madurez CTI en tres fases

Fase	Horizonte	Capacidades incorporadas
1. Fundamentos	0–3 meses	Feeds OSINT gratuitos, cultura anti-phishing, procesos básicos de reporte.
2. Estructura	3–9 meses	Adopción de MITRE ATT&CK, despliegue de MISP, simulacros técnicos internos.
3. Inteligencia proactiva	9–18 meses	Caza de amenazas por hipótesis, integración con el SOC, tableros para el directorio.

Nota. Madurez CTI.

Referencias

- Bianco, D. J. (2013). *The pyramid of pain*. Enterprise Detection & Response. <http://detect-respond.blogspot.com/2013/03/the-pyramid-of-pain.html>
- Congreso de la República del Perú. (2013). *Ley N.º 30096, Ley de Delitos Informáticos*. Diario Oficial El Peruano.
- Hubbard, D. W. y Sciersen, R. (2023). *How to measure anything in cybersecurity risk* (2.ª ed.). Wiley.
- International Organization for Standardization. (2018). *ISO 31000:2018. Risk management — Guidelines*. ISO.
- International Organization for Standardization e International Electrotechnical Commission. (2022). *ISO/IEC 27001:2022. Information security, cybersecurity and privacy protection — Information security management systems — Requirements*. ISO/IEC.
- Strom, B. E., Applebaum, A., Miller, D. P., Nickels, K. C., Pennington, A. G. y Thomas, C. B. (2018). *MITRE ATT&CK: Design and philosophy*. The MITRE Corporation.
- The MITRE Corporation. (2024). *MITRE ATT&CK Enterprise matrix*. <https://attack.mitre.org/>
- Verizon. (2024). *2024 Data Breach Investigations Report*. Verizon Business.